



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Russian State-Supported Cyber Actors Conduct Phishing Campaign Targeting Users of Zimbra Collaboration Suite

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-23
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Russian State-Supported Cyber Actors Conduct Phishing Campaign Targeting Users of Zimbra Collaboration Suite - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-23 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Russian State-Supported Zimbra Collaboration Suite Phishing and View-Based Exploit Campaign

1. Executive Summary

CISA and international partners published advisory AA26-204A describing Russian state-supported activity targeting organizations that use Zimbra Collaboration Suite (ZCS). The advisory states that the activity has targeted Western government and commercial organizations since at least July 2025 and is primarily focused on covert acquisition of email data.

The priority technical concern is CVE-2025-66376, a Zimbra vulnerability patched in November 2025. CISA describes a campaign that moved beyond ordinary credential phishing: the reported exploit can be triggered when a user views a malicious email in a vulnerable webmail instance, after which the activity attempts to collect recent mail, the Global Address List, and other sensitive account data.

Defenders should treat vulnerable ZCS webmail as both an external application exposure and a sensitive identity/email-data exposure. Priority actions are to confirm ZCS patch level, hunt for suspicious mailbox access and exfiltration, review persistence in compromised accounts, and enforce phishing-resistant authentication for administrator and high-value mail users.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-66376
Product / Component	Zimbra Collaboration Suite webmail
Weakness	View-based exploit path against vulnerable webmail; exact exploit mechanics should be validated against vendor guidance and CISA technical appendix
Severity	High operational priority due to reported state-supported exploitation and mailbox data exposure
Affected Versions	Vulnerable ZCS versions before the November 2025 fix; validate exact branch/version scope against Zimbra/vendor release notes
Fixed Versions	ZCS releases containing the November 2025 patch for CVE-2025-66376
Disclosure Date	2026-07-23 advisory publication; exploitation reportedly since at least July 2025
Exploitation Status	Reported active exploitation by Russian state-supported actors; CISA advisory AA26-204A

3. Source Review & Confidence

Source	Contribution	Confidence
CISA AA26-204A	Primary advisory, campaign description, targeted software, exploitation behavior, and mitigations	High

Australian Signals Directorate / cyber.gov.au republication	International partner corroboration and defender framing	High
U.S. Department of Defense advisory PDF mirror	Durable PDF distribution of the CSA and STIX artifact references	Medium
Lost Boys Cyber analysis	Operational prioritization, detection translation, and sector impact assessment	Medium

Confidence is highest for the existence of the advisory, the named target product, and the stated Russian state-supported campaign objective. Confidence is medium for environment-specific exposure until each organization validates its ZCS version, mail telemetry retention, and whether the suspicious indicators in the advisory appear locally.

4. Vulnerability Details

The advisory describes LAUNDRY BEAR activity against Zimbra Collaboration Suite users. Earlier activity reportedly relied on common access methods such as password spraying, phishing, and pass-the-cookie. The current ZCS campaign is more concerning because it uses a view-based exploit path: a victim may only need to view a malicious message in vulnerable webmail for the exploit attempt to run.

Once triggered, the exploit attempts to exfiltrate the victim's last 90 days of email communications, the organization Global Address List, and other sensitive information to actor-controlled infrastructure. The advisory also states that the activity attempts persistent access to victim accounts through multiple methods. For defenders, this means remediation cannot stop at deleting a malicious message; account state, mail rules, delegated access, sessions, and mailbox audit history need review.

5. Attack Scenarios

- A vulnerable internet-facing ZCS webmail deployment receives a malicious message; the target views the message and mailbox content is staged or exfiltrated.
- An initially compromised mailbox is used to gather address-book data, refine follow-on phishing, and pivot into additional government, defense, or commercial users.
- A patched environment still faces residual risk if pre-patch compromise established mailbox rules, delegated access, active sessions, OAuth-style grants, or stolen credentials.

6. Threat Landscape & Exploitation Status

CISA attributes the activity to Russian state-supported cyber actors and notes overlapping public industry tracking, including LAUNDRY BEAR. The target set described by the advisory includes Western government and commercial organizations. This campaign should be prioritized because email compromise enables intelligence collection, source compromise, sensitive negotiation or legal-data exposure, and credible internal phishing.

The vulnerability is older than the advisory publication date and reportedly patched in November 2025, but CISA's warning indicates that organizations remain exposed where patching, detection, or post-compromise review lagged. The operational lesson is that mail platforms need vulnerability management plus identity controls and mailbox-level hunting.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing ZCS webmail	Direct exploit reachability and high likelihood of targeted delivery attempts
Government, defense, and diplomatic mailboxes	High intelligence value and plausible Russian state collection interest
Commercial organizations using ZCS for executive/legal/partner communications	Sensitive mail and address-book data can support downstream social engineering

Patched ZCS but no compromise review	Historical exploitation may have left persistent mailbox access or stolen credentials
--------------------------------------	---

8. Mitigation and Workarounds

1. Patch Zimbra Collaboration Suite to a version that includes the fix for CVE-2025-66376.
2. Search mail gateway and ZCS logs for malicious-message delivery, suspicious webmail access, abnormal mailbox exports, and unusual requests around message-view events.
3. Reset credentials and revoke sessions for affected or high-risk accounts if evidence suggests mailbox access.
4. Review mailbox rules, forwarding, delegated access, application passwords, active sessions, and anomalous authentication methods.
5. Enforce phishing-resistant MFA for administrators, executives, legal, IT, and externally exposed webmail users.
6. Preserve logs before rotation; mailbox compromise investigations are often limited by short audit retention.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
ZCS webmail access followed by large mailbox reads or exports	Zimbra mailbox/web logs, reverse proxy logs	Identify post-exploit collection behavior
New forwarding/delegation/mail rule changes after suspicious webmail session	Mail audit logs, ZCS admin logs	Detect persistence and covert collection setup
Repeated failed then successful access against ZCS accounts	Auth logs, IdP logs, VPN/proxy logs	Catch password spraying/pass-the-cookie style access
Outbound connections from mail server to rare external hosts after message view	EDR/network telemetry	Surface exploit callback or exfiltration attempts

9.2. Sigma / Detection Rule

```

title: Suspicious Zimbra Mailbox Collection or Persistence After Webmail Access
id: 5e27f4c8-7c9e-4da2-9a59-zimbra-aa26204a-001
status: experimental
description: Detects mailbox export, forwarding, or delegation activity near suspicious Zimbra webmail access patterns aligned to AA26-204A triage.
references:
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-204a
logsource:
  product: zimbra
  service: mailbox
detection:
  suspicious_actions:
    event.action|contains:
      - ExportMailbox
      - CreateForwardingRule
      - ModifyFilterRule
      - GrantDelegateAccess
  suspicious_path:
    url.path|contains:
      - /zimbra/
      - /service/home/
  condition: suspicious_actions or suspicious_path
fields:
  - user.name

```

```

- source.ip
- url.path
- event.action
- http.user_agent
falsepositives:
- legitimate administrator mailbox export or migration activity
level: high

```

9.3. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(30d)
| where InitiatingProcessCommandLine has_any ("zimbra", "mailbox", "jetty") or DeviceName has_any ("zimbra", "mail")
| summarize Connections=count(), RareDestinations=dcount(RemoteUrl),
SampleDestinations=make_set(RemoteUrl, 20) by DeviceName, InitiatingProcessFileName, bin(Timestamp, 1d)
| where Connections > 25 or RareDestinations > 10

```

10. Threat Hunting

10.1. Hunt Hypothesis

A vulnerable or previously compromised ZCS mailbox will show anomalous mailbox access, export-like behavior, new persistence settings, or unusual outbound traffic from mail infrastructure near delivery of a malicious message.

10.2. Hunt Query

```

SigninLogs
| where TimeGenerated > ago(30d)
| where AppDisplayName has_any ("Zimbra", "Webmail", "Mail") or ResourceDisplayName has_any ("Zimbra", "Webmail")
| summarize Successes=countif(ResultType == 0), Failures=countif(ResultType != 0),
IPs=dcount(IPAddress), Countries=make_set(Location, 10) by UserPrincipalName, bin(TimeGenerated, 1d)
| where Failures > 10 or IPs > 3

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1566	Phishing	Advisory describes malicious email delivery and phishing activity targeting ZCS users
T1190	Exploit Public-Facing Application	Vulnerable webmail is an externally reachable application surface
T1114	Email Collection	Advisory states the campaign attempts to exfiltrate recent email communications
T1087	Account Discovery	Global Address List collection supports account and relationship discovery
T1098	Account Manipulation	Persistence review should include mailbox rules, delegation, and account changes

12. Validation / Lab Testing

No exploit reproduction was performed during this automated daily run. Validation completed: source corroboration, control-mapping review, detection-query drafting, and PDF text extraction after render. Operators should test Sigma field mappings against local Zimbra, proxy, and IdP schemas before production alerting.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Messaging / Infrastructure	Confirm ZCS versions and apply the CVE-2025-66376 patch where needed
Critical	SOC / IR	Hunt for suspicious mailbox access, export behavior, and persistence settings since July 2025 where logs permit
High	Identity	Enforce phishing-resistant MFA and revoke risky sessions for privileged or high-value mail users
High	Legal / Executive IT	Review sensitive mailbox exposure and preserve evidence if compromise indicators are found
Medium	Detection Engineering	Tune the included mailbox, sign-in, and network hunts to local telemetry

14. References

- [1] CISA, Russian State-Supported Cyber Actors Conduct Phishing Campaign Targeting Users of Zimbra Collaboration Suite, AA26-204A, 2026-07-23: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-204a>
- [2] Australian Signals Directorate / cyber.gov.au advisory republication: <https://www.cyber.gov.au/about-us/view-all-content/alerts-and-advisories/russian-state-supported-cyber-actors-conduct-phishing-campaign-targeting-users-of-zimbra-collaboration-suite>
- [3] U.S. Department of Defense advisory PDF mirror: https://media.defense.gov/2026/Jul/22/2003965244/-1/-1/0/CSA_RUSSIA_PHISHING_TARGET_ZIMBRA.PDF